

Production S3-Only Thumbnail Storage

Implementation comparison, deployment prerequisites, and verification evidence

Executive outcome

Phase 6 removes the unsafe production fallback that could bind a shared MongoDB record to one EC2 instance's filesystem. Production thumbnail writes now succeed in S3 before a shared HTTPS URL can be persisted; failures return a controlled 503 and preserve existing data.

10 / 10

Focused thumbnail tests

34 / 34

Relevant course/admin/video tests

196 / 198

Complete backend suite*

YES

Ready to deploy after config verification

* Two unrelated annual-billing assertions remain failing (expected 201/409, received 500). No billing files were changed; the thumbnail scope is green.

Before vs after

Production failure	S3 errors were swallowed; code wrote to local uploads/course-thumbnails .	Returns controlled 503 Storage temporarily unavailable ; no production filesystem write.
Stored location	MongoDB could receive an EC2-local /uploads/... URL.	MongoDB receives an HTTPS CDN/S3 URL only after a successful upload.
Replacement safety	Fallback could mask a failed shared upload and replace the prior URL.	A failed replacement stops before mutation/save; the existing valid URL remains.
Validation	MIME and decoded size checks; base64 content signatures were not verified.	JPEG/PNG/WebP MIME, canonical base64, 2 MB limit, magic bytes, safe ID/orientation.
Credentials	SDK dependency declared; IAM intent present.	Singleton S3 client uses the default provider chain; no static keys or ACL supplied.
URL policy	Configured CDN URL returned when present.	CDN preferred; regional S3 fallback. Local, IP, .local, and EC2 hostnames rejected.

Scope boundary

Changed only backend thumbnail storage, course thumbnail URL validation, configuration comments, and focused tests. Redis, cron locking, rate limits, authentication, OTP, payments, MongoDB pooling, infrastructure, and frontend code were not modified.

Implementation and production contract

Request and persistence flow

- Input remains a JSON data URL; Express accepts JSON up to 15 MB, while decoded thumbnail content is capped at 2 MB.
- No multipart upload middleware is involved. JPEG, PNG, and WebP are the only accepted MIME types.
- The service validates canonical base64 and matching file signatures before constructing the S3 request.
- Keys use **course-thumbnails/<course-id>/<orientation>-<sha256>.<ext>**, preventing traversal and accidental overwrite.
- S3 upload occurs before Course construction/save on create, and before applying/saving replacement fields on update.
- The response URL uses **THUMBNAIL_CDN_BASE_URL** when configured; otherwise it uses a regional S3 HTTPS URL.

Files changed

edunex-b/services/thumbnailCdn.js	Validated S3 upload, safe object key, singleton IAM-backed client, shared URL policy.
edunex-b/services/thumbnailStorage.js	Environment boundary: production fail-closed; explicit non-production local fallback.
edunex-b/server.js	Routes use the storage service; production external thumbnail URLs require shared HTTPS hosts.
edunex-b/tests/thumbnail-cdn.test.cjs	Ten focused success, failure, validation, safety, and persistence tests.
edunex-b/package.json	Adds the test:thumbnail-storage command; no second S3 library.
edunex-b/.env.example	Documents bucket, region, CDN, and IAM/default-chain expectations.

Production environment and IAM

NODE_ENV	Set to production to enforce fail-closed S3-only behavior.
THUMBNAIL_S3_BUCKET	Required bucket name.
THUMBNAIL_S3_REGION or AWS_REGION	At least one must provide the bucket/client region.
THUMBNAIL_CDN_BASE_URL	Optional in code; verify it for private S3 + CloudFront/OAC deployments. Must be permanent HTTPS and non-local.
EC2 IAM role	Allow s3:PutObject on arn:aws:s3:::<bucket>/course-thumbnails/* . No ACL permission is required.
CloudFront/OAC	For private objects, verify the distribution and bucket policy permit CloudFront s3:GetObject on that prefix.

No AWS access-key variables are required or introduced. The AWS SDK client receives only the region and resolves credentials through its normal provider chain, including the EC2 instance profile.

Verification and release readiness

Executed checks

Clean dependency install	PASS	npm ci added 141 packages; audit reported 0 vulnerabilities. @aws-sdk/client-s3 3.1131.0 resolves successfully.
Focused thumbnail suite	10 / 10	S3/CDN success, no-CDN S3 URL, local-host rejection, no production fallback, dev fallback, validation, dependency, URL policy, update safety, create safety.
Relevant course/admin/video	34 / 34	Admin course lists, course playlists, thumbnails, video import, and CloudFront behavior.
Complete backend suite	196 / 198	Two annual-billing assertions fail outside Phase 6 scope; expected 201/409 but current billing controller returns 500.
Static/syntax checks	PASS	Node syntax checks and git diff --check pass. No static AWS credential names appear in the thumbnail service.

Phase 6 acceptance

PASS S3 SDK dependency	PASS Production S3-only	PASS Local production fallback removed
PASS Database updated only after upload success	PASS Existing thumbnail protected on failed replacement	PASS CDN/shared URL
PASS IAM role/default credential chain	PASS No static AWS secrets introduced	PASS Development behavior

READY TO DEPLOY
YES - after verifying bucket, region, EC2 role, and CDN/OAC configuration in production.

Operational notes

- No deployment was performed.
- Content-addressed objects can become orphaned if a later database save or a second-orientation upload fails. Consider an S3 lifecycle rule or a future explicit cleanup workflow.
- When using a private bucket, configure the CDN base; the direct S3 URL fallback is usable only when bucket access permits it. Do not add public-read ACLs.
- Legacy /uploads serving remains intact for unrelated and development behavior, but new production course-thumbnail writes do not depend on it.